

SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN

ISO 27001:2022

Servientrega S.A.

Abril 2026

1. CONTEXTO Y ALCANCE

1.1 Contexto de la Organización

Nombre: Servientrega S.A.

Dirección: Carrera 106 No. 15A-25, Bogotá D.C., Colombia

NIT: 860.034.313-7

Sector: Terciario (servicios de transporte y logística)

Tamaño: Grande más de 10.000 empleados, activos superiores a 100.000 millones de pesos

Servicios principales: Mensajería y paquetería nacional, logística y distribución empresarial, recaudo y pagos, servicios internacionales

Misión

Satisfacer totalmente las necesidades de logística y comunicación integral de nuestros

Clientes, a través de la excelencia en el servicio, el desarrollo integral de nuestros Líderes de Acción y el sentido de compromiso con nuestra familia y nuestro País.

Visión

Queremos que Servientrega sea un modelo de empresa innovadora, líder en servicios de logística y comunicación, por seguridad, oportunidad y cubrimiento en América, con presencia competitiva a nivel mundial.

1.2 Alcance del SGSI

El SGSI de Servientrega S.A. aplica a la protección de la información relacionada con los procesos de gestión de envíos, datos de clientes, sistemas de rastreo, plataformas digitales de recaudo y pagos, recursos humanos e infraestructura tecnológica en las sedes principales ubicadas en Bogotá D.C.

Incluye todos los activos físicos y lógicos, procesos operativos y administrativos, así como el personal interno, contratistas y proveedores que accedan a los sistemas de información de la organización.

2. INVENTARIO DE ACTIVOS DE INFORMACIÓN

C = Confidencialidad | I = Integridad | D = Disponibilidad | A = Alto | M = Medio | B = Bajo

ID	Activo	Tipo	Descripción	Dueño	Ubicación	C	I	D	Criticidad
A1	Base de datos de clientes	Información	Datos personales y de envíos de clientes	Gerencia de TI	Nube	A	A	A	Alta
A2	Sistema de rastreo de paquetes	Software	Plataforma web y móvil de seguimiento de envíos	Gerencia de TI	Nube	M	A	A	Alta
A3	Servidores principales	Hardware	Servidores que alojan aplicaciones críticas	Gerencia de TI	Servidor local	A	A	A	Alta
A4	Red corporativa	Servicio	Infraestructura de red interna y externa	Gerencia de TI	Oficina	A	A	A	Alta
A5	Sistema de gestión de envíos	Software	Software de registro y control de paquetes	Gerencia Operativa	Nube	A	A	A	Alta
A6	Computadores área contable	Hardware	Equipos usados para gestión financiera	Gerencia Financiera	Oficina	A	A	M	Alta
A7	Correo electrónico corporativo	Servicio	Plataforma de comunicación interna	Gerencia de TI	Nube	A	M	A	Alta
A8	Base de datos de empleados	Información	Datos personales y laborales del personal	Gestión Humana	Nube	A	A	M	Alta
A9	Sistema de recaudo y pagos	Software	Plataforma de cobros y transacciones en línea	Gerencia Financiera	Nube	A	A	A	Alta
A10	Cámaras de seguridad	Hardware	Sistema de vigilancia en bodegas y oficinas	Gerencia de Seguridad	Oficina	M	M	A	Media
A11	Página web corporativa	Software	Sitio web servientrega.com.co	Gerencia de TI	Nube	M	A	A	Media
A12	Contratos con clientes	Información	Documentos legales de acuerdos comerciales	Gerencia Jurídica	Oficina	A	A	M	Alta
A13	Personal de TI	Persona	Equipo responsable de sistemas e infraestructura	Gerencia de TI	Oficina	A	A	A	Alta
A14	Sistema de control de acceso	Hardware	Torniquetes y lectores biométricos en sedes	Gerencia de Seguridad	Oficina	A	M	A	Alta

ID	Activo	Tipo	Descripción	Dueño	Ubicación	C	I	D	Criticidad
A15	Backups de información	Información	Copias de seguridad de datos críticos	Gerencia de TI	Nube	A	A	A	Alta

3. MATRIZ DE RIESGOS

C = Confidencialidad | I = Integridad | D = Disponibilidad

Activo	Amenaza	Vulnerabilidad	Probabilidad	Impacto (C/I/D)	Tratamiento
Base de datos de clientes	Acceso no autorizado	Contraseñas débiles	Alta	C, I	Mitigar
Base de datos de clientes	Robo de información	Falta de cifrado	Media	C	Mitigar
Sistema de rastreo de paquetes	Caída del sistema	Falta de redundancia	Media	D	Mitigar
Sistema de rastreo de paquetes	Ataque DDoS	Sin protección perimetral	Alta	D	Mitigar
Servidores principales	Malware	Sistema sin parches de seguridad	Alta	C, I, D	Mitigar
Servidores principales	Fallo eléctrico	Sin UPS ni generador	Media	D	Mitigar
Red corporativa	Interceptación de datos	Red sin cifrado	Media	C	Mitigar
Red corporativa	Acceso no autorizado	Falta de segmentación de red	Alta	C, I	Mitigar
Sistema de gestión de envíos	Error humano	Usuarios sin capacitación	Alta	I	Mitigar
Sistema de gestión de envíos	Modificación no autorizada	Falta de controles de acceso	Media	I	Evitar
Computadores área contable	Robo de equipos	Falta de seguridad física	Baja	C, I	Transferir
Correo electrónico corporativo	Phishing	Usuarios sin capacitación	Alta	C	Mitigar
Base de datos de empleados	Fuga de información	Acceso sin restricciones	Media	C	Mitigar
Sistema de recaudo y pagos	Fraude electrónico	Falta de autenticación doble	Alta	C, I	Mitigar
Sistema de recaudo y pagos	Interrupción del servicio	Dependencia de un solo proveedor	Media	D	Transferir
Cámaras de seguridad	Fallo del sistema	Falta de mantenimiento	Baja	D	Aceptar
Página web corporativa	Defacement	Vulnerabilidades en el código	Media	I	Mitigar
Contratos con clientes	Pérdida de documentos	Sin copias de respaldo	Baja	C, I	Mitigar
Personal de TI	Renuncia o ausencia	Falta de personal de respaldo	Media	D	Mitigar

Activo	Amenaza	Vulnerabilidad	Probabilidad	Impacto (C/I/D)	Tratamiento
Backups de información	Corrupción de datos	Backups sin verificación	Media	I, D	Mitigar

4. POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN

4.1 Objetivo

Proteger la información de Servientrega S.A. garantizando la Confidencialidad (solo acceden quienes deben), la Integridad (la información no se altera sin autorización) y la Disponibilidad (la información está disponible cuando se necesita), con el fin de asegurar la continuidad del negocio y proteger a clientes, empleados y socios comerciales.

4.2 Alcance

¿A quién aplica? A todos los empleados, contratistas, proveedores y terceros que accedan a los sistemas, datos e infraestructura tecnológica de Servientrega.

¿Qué cubre? Toda la información manejada en los procesos de gestión de envíos, recaudo, atención al cliente, recursos humanos y operaciones logísticas, tanto en formato digital como físico.

4.3 Roles y Responsabilidades

- Gerencia General: Aprobar y respaldar la política de seguridad
- Gerencia de TI: Implementar y mantener los controles de seguridad
- Gestión Humana: Capacitar al personal en seguridad de la información
- Todos los empleados: Cumplir las reglas establecidas en esta política
- Oficial de Seguridad: Monitorear el cumplimiento y gestionar los incidentes

4.4 Reglas Generales

- Las contraseñas deben tener mínimo 8 caracteres, combinando letras, números y símbolos
- Está prohibido compartir contraseñas con otros usuarios
- Los equipos deben bloquearse al ausentarse del puesto de trabajo
- Solo se puede acceder a la información necesaria para el desempeño del cargo
- Está prohibido instalar software no autorizado en los equipos de la empresa
- La información confidencial no puede enviarse por correos personales
- Los incidentes de seguridad deben reportarse inmediatamente al área de TI
- El acceso remoto solo se permite a través de VPN autorizada
- Los dispositivos externos (USB, discos) deben ser autorizados por TI antes de usarse
- Está prohibido acceder a sistemas de la empresa desde redes WiFi públicas
- Toda la información crítica debe tener copias de respaldo actualizadas
- Los contratos y documentos físicos confidenciales deben guardarse bajo llave

4.5 Cumplimiento

El incumplimiento de esta política acarreará las siguientes consecuencias:

- Falta leve: Llamado de atención verbal o escrito
- Falta grave: Suspensión temporal sin goce de salario

- Falta gravísima: Terminación del contrato y posibles acciones legales

Lo anterior aplica sin perjuicio de las responsabilidades civiles o penales que puedan derivarse según la legislación colombiana vigente.

4.6 Revisión

Esta política será revisada anualmente o cuando ocurra alguno de los siguientes eventos:

- Cambios significativos en la infraestructura tecnológica
- Incidentes de seguridad graves
- Cambios en la legislación aplicable

5. DECLARACIÓN DE APLICABILIDAD

5.1 Controles que Aplican (15)

Control	Descripción	¿Aplica?	Justificación	Riesgo Asociado
A.5.1 Políticas de seguridad	Establecer y comunicar políticas de seguridad	Sí	Servientrega maneja información crítica de clientes y envíos	Acceso no autorizado
A.6.1 Roles y responsabilidades	Definir responsabilidades de seguridad	Sí	La empresa tiene múltiples áreas que manejan información sensible	Error humano
A.6.3 Concientización y formación	Capacitar al personal en seguridad	Sí	Los empleados son el principal vector de ataque por phishing	Phishing
A.7.1 Control de acceso físico	Controlar el acceso físico a instalaciones	Sí	Las bodegas y centros de distribución requieren control de acceso	Robo de equipos
A.7.4 Monitoreo de seguridad física	Vigilar instalaciones con cámaras	Sí	Servientrega tiene bodegas con mercancía y equipos valiosos	Robo de equipos
A.8.2 Gestión de accesos privilegiados	Controlar accesos de administradores	Sí	Los sistemas críticos deben tener accesos restringidos	Acceso no autorizado
A.8.5 Autenticación segura	Implementar autenticación fuerte	Sí	Los sistemas de pagos y clientes requieren doble autenticación	Fraude electrónico
A.8.7 Protección contra malware	Instalar antivirus y antimalware	Sí	Los servidores y equipos están expuestos a malware	Malware
A.8.8 Gestión de vulnerabilidades	Aplicar parches de seguridad	Sí	Los sistemas deben mantenerse actualizados	Malware
A.8.10 Eliminación de información	Borrar datos de forma segura	Sí	Los datos de clientes deben eliminarse correctamente al vencer contratos	Robo de información
A.8.13 Copias de respaldo	Realizar backups periódicos	Sí	La información crítica debe respaldarse para garantizar continuidad	Corrupción de datos
A.8.16 Monitoreo de actividades	Registrar y monitorear eventos del sistema	Sí	Permite detectar accesos sospechosos a tiempo	Acceso no autorizado
A.8.20 Seguridad en redes	Proteger la red corporativa	Sí	La red transporta información confidencial de clientes y pagos	Interceptación de datos
A.8.24 Uso de criptografía	Cifrar información sensible	Sí	Los datos de clientes y pagos deben viajar cifrados	Robo de información
A.8.32 Gestión de cambios	Controlar cambios en sistemas	Sí	Los cambios sin control pueden generar vulnerabilidades	Modificación no autorizada

5.2 Controles que No Aplican (10)

Control	Descripción	¿Aplica?	Justificación	Riesgo Asociado
A.5.7 Inteligencia de amenazas	Recopilar info sobre amenazas externas	No	Servientrega no tiene un equipo especializado en ciberinteligencia	N/A
A.6.6 Acuerdos de confidencialidad con terceros	Firmar NDA con proveedores externos	No	Los contratos actuales ya incluyen cláusulas de confidencialidad suficientes	N/A
A.7.5 Trabajo en áreas seguras	Zonas especiales de alta seguridad	No	No maneja información clasificada que requiera zonas de alta seguridad	N/A
A.8.1 Dispositivos de usuario final	Gestión de dispositivos móviles corporativos	No	No todos los empleados usan dispositivos móviles corporativos	N/A
A.8.11 Enmascaramiento de datos	Ocultar datos sensibles en pruebas	No	No se realizan pruebas de software con datos reales de producción	N/A
A.8.17 Sincronización de relojes	Sincronizar relojes de sistemas	No	Los sistemas actuales ya están sincronizados automáticamente	N/A
A.8.21 Seguridad en servicios de red	Gestionar servicios de red externos	No	Los servicios de red son provistos por terceros con sus propios controles	N/A
A.8.28 Codificación segura	Aplicar buenas prácticas de desarrollo	No	Servientrega no desarrolla software propio, usa soluciones de terceros	N/A
A.8.29 Pruebas de seguridad en desarrollo	Realizar pruebas de seguridad en apps	No	No aplica porque no desarrollan aplicaciones internamente	N/A
A.8.33 Información de pruebas	Proteger datos usados en pruebas	No	No se usan datos reales en ambientes de prueba	N/A

5.3 Procedimientos Detallados de 3 Controles

Procedimiento 1: A.8.5 — Autenticación Segura

Objetivo: Garantizar que solo usuarios autorizados accedan a los sistemas de Servientrega.

- Todo usuario debe tener un usuario y contraseña únicos e intransferibles
- Las contraseñas deben tener mínimo 8 caracteres, combinando mayúsculas, minúsculas, números y símbolos
- Las contraseñas deben cambiarse cada 90 días obligatoriamente
- Se implementará autenticación de doble factor (2FA) en sistemas críticos como pagos y base de datos de clientes
- Después de 5 intentos fallidos el sistema bloqueará automáticamente el acceso
- El área de TI es responsable de crear, modificar y eliminar accesos

- Cuando un empleado se retire, su acceso debe desactivarse el mismo día

Responsable: Gerencia de TI

Frecuencia de revisión: Semestral

Procedimiento 2: A.8.7 — Protección contra Malware

Objetivo: Prevenir, detectar y eliminar software malicioso en los sistemas de Servientrega.

- Todos los equipos deben tener antivirus instalado y actualizado automáticamente
- El antivirus realizará escaneos completos cada semana de forma automática
- Está prohibido desactivar el antivirus bajo cualquier circunstancia
- No se permite descargar software no autorizado por el área de TI
- Los correos con archivos adjuntos sospechosos deben reportarse inmediatamente a TI
- Los dispositivos USB deben escanearse antes de conectarse a cualquier equipo
- En caso de detectar malware, el equipo afectado debe aislarse de la red inmediatamente
- El área de TI documentará cada incidente de malware detectado

Responsable: Gerencia de TI

Frecuencia de revisión: Trimestral

Procedimiento 3: A.8.13 — Copias de Respaldo

Objetivo: Garantizar la disponibilidad y recuperación de la información crítica de Servientrega ante cualquier incidente.

- Se realizarán backups diarios automáticos de las bases de datos de clientes y envíos
- Los backups se almacenarán en la nube y en un servidor local como doble respaldo
- Las copias de respaldo se conservarán por un período mínimo de 90 días
- Cada mes se realizará una prueba de restauración para verificar que los backups funcionan correctamente
- El acceso a los backups estará restringido únicamente al personal autorizado de TI
- En caso de pérdida de información, el tiempo máximo de recuperación será de 4 horas
- El responsable de TI generará un informe mensual del estado de los backups

Responsable: Gerencia de TI

Frecuencia de revisión: Mensual